# INTERNET IDENTITY CARD — VERIFICATION ARCHITECTURE

VerifBox file time-stamping · IIC TSA (RFC 3161 / RFC 5816) · two-level offline PKI · 12-year retention issuance journal · daily third-party anchoring · independent verifiers

Architecture as deployed on 10 October 2026, updated 11 October 2026 · Version 1.1 · HTTPS CARD — INTERNET IDENTITY CARD LIMITED, England and Wales no. 09168431, 124 City Road, London EC1V 2NX · IANA PEN 67100

3 distinct proofs, 3 trust roots | file never leaves the device | only a SHA-256 fingerprint travels | no hash, no IP in any log | not eIDAS-qualified · not certified | IIC TSA and VerifBox: same company, disclosed

## 1 · TIME-STAMPING A FILE (issuance path)

### USER DEVICE (browser)

The file is opened locally. Its SHA-256 fingerprint is computed in the browser (Web Crypto, streamed, progress bar). Nothing else is read.

Sent to the engine: one JSON field, the 64-hex fingerprint. Not sent: file, name, size, identity. No account.

Received back and kept by the user (VerifBox keeps no copy):

`<name>.verifbox.json — the proof (authoritative)`
`<name>.verifbox-fichier.ots — Bitcoin anchor ① (file)`
`<name>.verifbox-attestation.ots — Bitcoin anchor ② (attestation)`
`PDF certificate — readable presentation, once anchor ① is confirmed`

Later: the browser can call /api/completer to upgrade the .ots files once the Bitcoin block exists (pending → confirmed, block height + txid).

SHA-256 only →

← proof + 2 .ots + token

### VERIFBOX ENGINE — verifbox.com (Cloud Run, europe-west1)

POST /api/horodater {empreinte} → rate-limited per client address; fingerprint validated (^[0-9a-f]{64}$).

**ATTESTATION (signed content)**

`format "verifbox-preuve-1" · issuer · algorithm SHA-256 · fingerprint · time UTC (ms, Z) · random identifier (UUID4) · key identifier 258e57366bcdb6ce`
`Canonical JSON of this object is what both signatures cover.`

**SIGNATURE 1 — Ed25519 (RFC 8032)**

Classical signature, verifiable with any standard library (OpenSSL, libsodium, Web Crypto).

**SIGNATURE 2 — ML-DSA-65 (FIPS 204)**

Post-quantum signature over the same content. A future break of Ed25519 does not break authorship.

Keys: generated once, held in Secret Manager, loaded at start, self-tested; never in code or image. Key lifecycle published (in service since 2026-10-03 06:20 UTC); a retired key stays verifiable with its dates.

**IN PARALLEL (thread pool), none of them blocks the proof — the proof is returned even if they fail:**

**ANCHOR ①**

OpenTimestamps on the FILE fingerprint. Submitted to 4 calendars (a/b pool.opentimestamps.org, eternitywall, catallaxy). Verifiable with `ots verify` on the file alone.

**ANCHOR ②**

OpenTimestamps on the SHA-256 of the SIGNED ATTESTATION. Proves this exact attestation existed before the block: an attestation forged after a key theft cannot carry it.

**IIC TSA TOKEN**

RFC 3161 TimeStampReq (SHA-256 imprint = file fingerprint, random nonce, certReq) to the PRIVATE IIC TSA service, authenticated by the engine's service account (IAM, audience), 10 s budget.

TimeStampReq →

← TimeStampResp

**PROOF FILE .verifbox.json**

`{ contenu: {…attestation…}, signatures: {ed25519, ml_dsa_65}, ancrages: {bitcoin: {ots, etat}, attestation: {ots, etat}}, jetons: {iic_tsa: {tsr (DER, base64), serie, heure, politique, emetteur}} }`
`anchors and token sit OUTSIDE the signed content: they are added evidence, each verified on its own.`

Engine logs: no file content, no fingerprint, no IP address. Engine env: IIC_TSA_URL, IIC_TSA_AUDIENCE, IIC_TSA_DELAI=10. Pinned IIC TSA root in moteur/iic-tsa/racine.pem and published at /.well-known/iic-tsa.json.

### IIC TSA — tsa.internetidentitycard.com (Cloud Run, europe-west1)

public service iic-tsa · 60 req/min/address | private service iic-tsa-verifbox · IAM · 600/min

Same container image, same Cloud KMS key, same issuance journal. Policy OID 1.3.6.1.4.1.67100.1.1.1.1 (test: …67100.1.1.9.1, never accepted in production).

**1 PARSE**

DER TimeStampReq ≤ 8,192 bytes, version 1; SHA-256/384/512 only (SHA-1, MD5 → badAlg); BER, trailing bytes, certReq FALSE → badDataFormat; any extension → unacceptedExtension; foreign reqPolicy → unacceptedPolicy.

**2 TIME GUARDIAN (on demand, fail-closed)**

No background clock trust. Measures the system clock over TLS against 4 operators: PTB wss://uhr.ptb.de/time (traceable to UTC(PTB)), Akamai, Google, Cloudflare (HTTP Date bracketing). SYNC only if ≥ 3 usable sources incl. PTB, spread ≤ 250 ms, offset ≤ 100 ms, each source ≤ 2.5 s and ≤ 100 ms uncertainty. SYNC = 30 s lease; otherwise timeNotAvailable. Cloud Run blocks UDP: no NTP.

**3 SERIAL + JOURNAL (before signing)**

128-bit random serial, never derived from the request. Journal entry created ONLY IF ABSENT (one object per serial): serial, genTime, key generation, clock state, lease id, nonce present y/n, status, SHA-256 of the signature. NOT stored: imprint, nonce value, IP, body. Collision → new serial.

**4 SIGN — Cloud KMS EC_SIGN_P256_SHA256 (SOFTWARE)**

Private key never leaves KMS; least-privilege service account (signer + public-key viewer only). Pre-checks: KMS public key = certificate key, protection level as expected; CRC32C on digest and signature; low-S normalisation; local verification before release. KMS Data Access audit logs on.

**5 TOKEN — CMS SignedData / TSTInfo (RFC 5816)**

policy OID · messageImprint (exact copy) · serialNumber · genTime UTC whole second · accuracy 1 s · ordering FALSE · nonce (iff sent) · tsa = DirName of the TSA certificate · signed attribute ESSCertIDv2 (SHA-256). certReq → TSA certificate only, never the root.

Request-body and client-address logging disabled; Cloud Run request logs excluded by a logging sink exclusion. IP held in memory ≤ 1 minute for rate limiting only.

## 2 · TRUST ROOTS, EVIDENCE RETENTION AND PUBLICATION

### IIC TSA PKI — two levels, offline root, ceremonies

**ROOT — IIC TSA Root R1 (offline)**

ECDSA P-384, SHA-384 · valid 10 Oct 2026 → 9 Oct 2056 · CA:TRUE pathlen 0 · keyCertSign + cRLSign only · never signs a token.
SHA-256 86:52:E3:D1:3E:72:5F:7C:75:7C:FA:05:3D:64:13:60:AC:A4:43:CF:6C:09:D7:D6:DD:D4:4B:EA:85:1E:D3:B9
Ceremony: owner's computer, Docker --network none (Debian 13, OpenSSL 3.5), network and Wi-Fi off. Key stored PKCS#8 encrypted (scrypt + AES-256-CBC), passphrase ≥ 20 characters on paper, kept apart. Two USB backups of different brands, verified identical and decryptable; working copy deleted. Only root.pem, root.crl and the TSA certificate leave the ceremony. Used about once a year (CRL) and to certify a new TSA key.

**TSA CERTIFICATE — IIC TSA tsa-2026-a**

Key = the Cloud KMS P-256 key · issued directly by the root (no intermediate CA) · CA:FALSE · keyUsage digitalSignature · EKU id-kp-timeStamping ONLY, critical (no anyEKU) · SKI/AKI (RFC 7093) · CRL DP https://tsa.internetidentitycard.com/tsa/crl.
Valid 135 months (10 Oct 2026 → 9 Jan 2038); the key SIGNS for at most 15 months and is destroyed within 18 months. Next generation published before the switch; old key stays for verification.
SHA-256 E4:F9:8E:7A:ED:CD:1A:07:D8:1C:A5:9D:1C:19:92:AB:E7:85:7A:2C:A1:CC:8D:F6:9F:72:05:FF:AD:34:FB:E8

**REVOCATION AND COMPROMISE**

Single CRL of the hierarchy, DER, 365 days, re-issued yearly; emergency CRL at once on compromise, reason code + invalidity date = published trust-cutoff instant. Issuance stops (FAIL). Tokens before the cutoff keep their value only through the journal: a token whose signature digest appears in a daily batch time-stamped by DigiCert / anchored in Bitcoin BEFORE the cutoff was provably issued by the service. The root is not revoked for an incident limited to the TSA key. CRL retrieval failure → result undetermined, never valid.

**VERIFBOX SIGNING KEYS**

Ed25519 + ML-DSA-65 key pair, identifier 258e57366bcdb6ce. Public key file verifbox-cles.json (SHA-256 e0f8ef80…c565d) published in 3 independent places: verifbox.com/.well-known, GitHub httpscard/verifbox-cles, DNS TXT _verifbox.internetidentitycard.com (DNSSEC-signed zone). The TLS certificate of tsa.internetidentitycard.com and the VerifBox keys are never accepted as token signers.

### EVIDENCE RETENTION AND DAILY THIRD-PARTY ANCHORING

**ISSUANCE JOURNAL — Cloud Storage, create-only**

entries/<32 hex serial>: created only if absent, never overwritten (ifGenerationMatch=0); a token is returned only after its entry exists. Also the serial-reuse detector. Marks for 'not issued' (lease_expired, sign_failed, check_failed).
Retention policy 12 years (> 135-month certificate life); its irreversible lock is scheduled after the first weeks of operation (owner decision of 11 October 2026). No hash value, no nonce, no IP, no body → no personal data.

**NIGHTLY BATCH — Cloud Scheduler 00:20 UTC → Cloud Run job**

1. Collect all entries and marks of the previous UTC day → batches/journal-YYYY-MM-DD.jsonl (sorted, canonical JSON lines) + current root CRL.
2. SHA-256 of the file → RFC 3161 token from DigiCert's public TSA (policy 2.16.840.1.114412.7.1); FreeTSA as fallback; NEVER the IIC TSA itself.
3. Same SHA-256 → OpenTimestamps → Bitcoin blockchain (independent proof of existence, no trust in any company).
4. File + proofs + their SHA-256 copied to an ARCHIVE bucket in another region (europe-west4, Archive class, 12-year retention).
Third-party failure never blocks token issuance; they never become a source of genTime. Entries of a given day are provided to a relying party on request.

**WHAT THIS GIVES A RELYING PARTY**

- A token can be proven to have been issued by the service, on its day, from the digest of its signature — without revealing which document it covers (the signature digest cannot be computed without the token).
- An operator with a stolen key cannot back-date: a forged token's digest is absent from the batch anchored that day.
- The 12-year retention (to be locked), the KMS audit logs and the single-operator disclosure are the compensating controls for the absence of separation of duties.

Not promised: availability (FAIL → reject, never guess), qualification (eIDAS/UK eIDAS), certification (no HSM, no FIPS), independence from VerifBox, separation of duties.

### PUBLICATION — nothing rests on a single location

**tsa.internetidentitycard.com**

POST /tsa · GET /tsa/chain (root PEM) · /tsa/certificate · /tsa/crl, /tsa/root-crl (DER) · /tsa/status (clock state, key generation, dated notices) · /tsa/policy.json · /tsa/health (200 only in SYNC)

**www.internetidentitycard.com**

/tsa (service page, fingerprints, OpenSSL how-to) · Timestamp Policy v1.0 and Practice Statement v1.0 (PDF, SHA-256 listed) · /tsa-terms · privacy policy §3.4 · legal notice (services, hosting, same-company disclosure). Site itself sealed: SITE-SHA256SUMS, Ed25519 release key, service-worker offline copy, Bitcoin/Ethereum site-root proofs.

**verifbox.com**

/.well-known/verifbox-cles.json (signing keys) · /.well-known/iic-tsa.json (pinned root SHA-256 8652e3d1…d3b9, service URL, CRL path) · /.well-known/iic-tsa-racine.crl (second CRL location, survives a TSA outage or loss of domain) · /verify (browser verifier) · /specification

**DNS — internetidentitycard.com (DNSSEC)**

TXT _verifbox.internetidentitycard.com = fingerprint of verifbox-cles.json. Target: TXT records with the root and TSA certificate fingerprints, so the trust anchor can be checked without trusting the service or GitHub alone.

**GitHub — httpscard/verifbox-cles**

Keys, verifbox_verify.py (MIT, pinned root), verifbox-verify-offline.html (keys embedded verbatim), demo-iic-tsa/ (real proof 54b07a24, block 970,811, token .tsr, root PEM, verification transcript), policy and practice statement versions. Target: Software Heritage deposit.

**Bitcoin blockchain**

Anchors ① and ② of every VerifBox proof; nightly IIC TSA journal digests. Proof of existence before a block; not an RFC 3161 time and not a certification of the TSA's stated time.

## 3 · VERIFYING — independent paths, separate results, no single verdict

### VERIFIERS (any of them, without VerifBox being online)

**Browser — verifbox.com/verify**

Drop the proof and the file. Fingerprint recomputed locally; Ed25519 (Web Crypto) and ML-DSA-65 (JS); OTS parsed and block looked up; IIC TSA token decoded and checked by rfc3161.js against the pinned root. Each line of the result is one check.

**Offline HTML — verifbox-verify-offline.html**

Single file from GitHub; works with no internet, CSP forbids any request; public keys embedded verbatim (SHA-256 of the block = published fingerprint). For a user with no technical skill, years later.

**Python — verifbox_verify.py (MIT)**

pip install cryptography dilithium-py · checks fingerprint, both signatures, key lifecycle, DNS/GitHub publication, OTS, and the token: CMS signature, chain to PINNED_IIC_TSA_ROOTS, EKU, validity at genTime, CRL, policy OID, imprint, nonce. Written by the operator: a verifier independent of the encoder is still pending.

**OpenSSL / ots (no VerifBox code at all)**

openssl ts -reply -in token.tsr -text · openssl ts -verify -data file -in token.tsr -CAfile iic-tsa-root.pem (also -attime genTime) · ots verify file.ots · any Ed25519 library on contenu.

A verifier that cannot reach the CRL or a calendar reports UNDETERMINED for that check — never VALID by default.

### THE CHECKS — three proofs, three trust roots

**A · VERIFBOX ATTESTATION (trust root: VerifBox keys, published in 3 places)**

- A1 SHA-256 of the file = contenu.empreinte
- A2 Ed25519 signature valid over canonical contenu
- A3 ML-DSA-65 signature valid over the same bytes (post-quantum)
- A4 key identifier known, in service at contenu.horodatage; key file fingerprint = GitHub = DNS TXT (DNSSEC)

**B · BITCOIN ANCHORS (trust root: proof of work, no company)**

- B1 anchor ① commits to the FILE fingerprint; path to a Bitcoin block header; block height, time, txid
- B2 anchor ② commits to the SHA-256 of the signed attestation → this attestation existed before that block (defeats a post-theft forgery)
- B3 pending → confirmed through /api/completer or any OTS calendar; verifiable with `ots verify` alone

**C · IIC TSA TOKEN (trust root: IIC TSA Root R1 + UTC(PTB) traceability)**

- C1 CMS signature valid; ESSCertIDv2 matches the signing certificate
- C2 certificate chains to the pinned root (SHA-256 8652e3d1…d3b9); EKU id-kp-timeStamping critical; valid at genTime
- C3 not revoked at genTime, per a CRL issued after genTime (tsa/crl or verifbox.com copy); after a keyCompromise, genTime before the cutoff AND digest in an anchored batch
- C4 policy OID = 1.3.6.1.4.1.67100.1.1.1.1 (production), never the test OID; accuracy 1 s read from the token
- C5 messageImprint = the file fingerprint; nonce = the one sent

Result = one line per check. A proof with A valid and C absent is still a VerifBox proof (the token is an addition since 10 Oct 2026). A proof with B pending is valid and becomes stronger when the block is mined.

### WHY THREE ROOTS — failure analysis

**VerifBox key stolen**

Forged attestations fail B2 (no anchor ② before the block) and carry no IIC TSA token issued at the claimed time. Key retired, dates published; old proofs keep A4.

**IIC TSA key compromised**

Emergency CRL + cutoff; tokens before cutoff rest on the anchored journal batches (C3). VerifBox proofs keep A + B unchanged.

**VerifBox or IIC TSA offline / company gone**

Proof, .ots, token, root PEM and CRL copies are in the user's hands and on GitHub/DNS/Bitcoin; offline verifier needs no server. Tokens stay verifiable at their genTime.

**Clock attack on the TSA**

No token without SYNC against 4 operators incl. PTB; 1 s accuracy declared covers the worst SYNC case; 14-day campaign reviewed at day 14.

**Quantum computer breaks ECDSA/Ed25519**

ML-DSA-65 keeps authorship; Bitcoin anchors keep existence; token to be re-time-stamped before its algorithms weaken (operator announces in advance).

**Same company for TSA and VerifBox**

Disclosed everywhere (policy, pages, terms, proofs). Independence comes from B (Bitcoin), from DigiCert on the journal, and from PTB on time — none run by this company.

© 2026 HTTPS CARD — INTERNET IDENTITY CARD LIMITED. Descriptive record of the architecture as deployed on 10 October 2026 (public token issuance closed the same day; retention lock deferred on 11 October 2026), intended for time-stamping as prior art. Not a claim of eIDAS qualification, certification, accreditation or conformity to ETSI EN 319 421;
References: IIC TSA Timestamp Policy v1.0 (OID 1.3.6.1.4.1.67100.1.1.1.1) · IIC TSA Practice Statement v1.0 · VerifBox specification (verifbox.com/specification) · github.com/httpscard/verifbox-cles · internetidentitycard.com/tsa